

VAPT Growth Playbook

Oct 5, 2026 · @killyou

Read this first: what you can and cannot say

Partnering with an empanelled firm does not make "CERT-In compliant" or "CERT-In empanelled", and you cannot say either on your website. CERT-In's own terms restrict even empanelled firms to one exact sentence: *"This Organization is empanelled by CERT-In for providing information Security Auditing Service"* ([CERT-In auditor guidelines](#), [terms and conditions](#)). Using the name or logo without permission can get the partner de-empanelled, and it exposes you to misrepresentation claims.

Having a partner sign reports for testing you did is not the plan. For government and critical-sector audits, CERT-In requires the firm to deploy the staff it declared to CERT-In. A reputable partner will refuse to rubber-stamp your work, and a firm that agrees is one you should not trust with your clients. If a client ever asks who did the testing, the answer must be true.

Say this	Never say this
"CERT-In audits delivered with [Partner], a CERT-In empanelled auditor" (with the partner's written OK)	"CERT-In compliant", "CERT-In certified", "CERT-In approved"
"Our testers hold OSCP / CEH / eWPTX" (only if true)	The CERT-In logo anywhere on your site
"VAPT aligned to OWASP, PTES and NIST"	"Empanelled" in any form until you are
"Reports accepted for ISO 27001, SOC 2 and PCI DSS audits" (once you have proof)	Anything implying the partner's credentials are yours

The legitimate model: **you sell and run non-CERT-In VAPT yourself, and route CERT-In-mandated work to the partner, who tests it with their declared team.** If the partner wants to add your certified testers to their declared roster as consultants, that is their decision and CERT-In's process, not something you can claim on your own.

Team: start with 3, grow to 5–6

You can start selling with 3 people, but at least one must be a certified, hands-on penetration tester. Claude speeds up writing and analysis; it does not replace a human tester who signs off on findings.

Stage	Headcount	Roles	Can deliver
Start (months 0–3)	3	Founder/sales (you), 1 senior pentester (OSCP or equivalent), 1 junior tester/report writer	2–3 web/API VAPTs a month
Growth (months 3–9)	5	+ 1 mobile/cloud tester, + 1 part-time compliance consultant (ISO 27001 LA)	5–8 engagements a month, ISO/SOC 2 support
Empanelment-ready (12–24 months)	6–8+	Certified staff mix CERT-In asks for (e.g. CISSP, CISA, ISO 27001 LA, OSCP), a QA/report reviewer	CERT-In application

Certifications that win trust, in rough order of value for VAPT buyers: **OSCP / OSWE / OSEP** (hands-on), **eWPTX / CRTP / PNPT**, **CEH Practical**, **ISO 27001 Lead Auditor** (for compliance clients), **CISSP / CISA** (for empanelment and enterprise).

Cost-saving options: hire the senior tester as a per-project contractor at first, recruit juniors from null/OWASP communities and bug bounty leaderboards, and keep sales and reporting in-house with Claude's help.

Open question: who on your current team will do the testing, and what certifications do they hold? That decides whether you start in Phase 0 or must hire first.

Phase 0 (weeks 1–3): foundations

Fix what a security buyer checks in the first five minutes. Today saranik.in uses a personal Outlook address and has no SPF or DMARC records, so a prospect can see you haven't secured your own domain.

- ☐ Register the business properly (Pvt Ltd or LLP), GST, current account, and a professional address
- ☐ Move email to @saranik.in (Google Workspace or Zoho Mail) and add SPF, DKIM and DMARC in Hostinger DNS

- ☐ Run a VAPT on your own site and fix everything; it's your first sample report
- ☐ Build a dedicated VAPT page (saranik.in/vapt) or a separate security brand: services, methodology (OWASP, PTES, NIST), compliance covered, timeline, free retest, starting prices, "Book a scoping call"
- ☐ Add a Team section with real names, photos, LinkedIn links and verifiable certifications
- ☐ Create a redacted sample report (10–15 pages: executive summary, scope, findings with CVSS, evidence, fix steps, retest status)
- ☐ Prepare engagement documents: mutual NDA, Rules of Engagement, client authorization letter, scope sheet, SOW/proposal template, MSA
- ☐ Get professional indemnity / cyber liability insurance (enterprise clients will ask)
- ☐ Set up a secure evidence workflow: encrypted storage, client data deleted after a fixed period, written data-handling policy
- ☐ Publish 3–4 security blog posts and a company LinkedIn page

Never start testing without a signed authorization letter that names the exact targets and dates. Testing without one is an offence under the IT Act, even for a paying client.

Phase 1 (weeks 2–6): win a CERT-In partner

Partners say yes when you bring them clients they wouldn't get on their own. Lead with leads, not with a request for help.

Find them

1. Download CERT-In's [official list of empanelled auditors](#) (contact person, email and phone for each firm).
2. Shortlist 20–30 small and mid-size firms, preferably in Delhi NCR. Skip the Big 4 and large firms; they won't prioritise a small referrer.
3. Check each on LinkedIn: active posting, team size, and whether they already run a partner programme.
4. Find the founder or business-development head, not the generic inbox.

What to offer them

- **A steady referral flow** of clients who need CERT-In audits (fintech, NBFC, government vendors, SEBI-regulated entities)
- **Your existing clients:** every AI chatbot or WhatsApp agent you build touches customer data and is a VAPT lead
- **Overflow help** on non-CERT-In work (startup VAPT, report writing, AI/LLM app testing) if they're short-staffed

- **Zero sales cost to them:** you do the prospecting, scoping and client handling

Pitch (LinkedIn or email)

Hi [Name], I run Saranik, a Delhi-based AI automation and security firm. Our fintech and SaaS clients keep asking for CERT-In-compliant audits, which we can't sign. I'd like to send them to [Firm] as a referral partner. We handle the relationship and scoping; you run the audit. Open to a 15-minute call this week?

Follow up twice, 4–5 days apart. Expect roughly 1 call per 5–8 messages.

Objections and answers

They say	You answer
"Will you poach our clients?"	Offer a mutual non-solicitation clause for 2 years
"Are your leads real?"	Offer to start with one client and prove it
"We don't pay commission"	Propose a reseller model: you buy at a partner rate and bill the client
"Who handles quality?"	They test and sign; you never alter their report

Put it in writing

A one-page referral or reseller agreement covering: commission (typically 10–20%) or partner price, who owns the client relationship, non-solicitation, how leads are registered (a shared sheet with dates), payment terms, confidentiality, and the exact wording you may use about the partnership on your site.

Sign 2–3 partners, not one, so a single firm can't dictate terms or leave you stranded.

Phase 2 (week 4 onward): find VAPT clients

Target companies with a deadline: an audit, a funding round, an enterprise deal or a regulator. They buy fast.

Segment	Why they buy	Who does it	Contact
Your existing AI/WhatsApp clients	Your bots handle their customer data	Saranik	Owner

Segment	Why they buy	Who does it	Contact
Indian SaaS selling abroad	SOC 2 / ISO 27001 and customer security questionnaires	Saranik	CTO, founder
Funded startups (Seed-Series B)	Investor due diligence, enterprise sales	Saranik	CTO
Fintech, NBFCs, payment aggregators	RBI requirements	Partner (if CERT-In needed)	CISO, compliance head
Brokers, AMCs, DPs	SEBI CSCRF	Partner	CISO
Government / PSU vendors	Tenders require CERT-In audit	Partner	Bid / IT head
Hospitals, clinics, D2C, ed-tech	DPDP Act, payment data	Saranik	Founder, IT head

Channels, in order of payoff

1. **Existing clients:** offer every AI client a discounted security check of the bot and website.
2. **Referral partners:** ISO/SOC 2 consultants, CA firms, web/app agencies, MSPs. Offer 10–15% referral fee.
3. **LinkedIn outreach:** 20 personalised messages a day to CTOs and founders in the segments above.
4. **Cold email:** from a warmed-up `@saranik.in` domain with SPF/DKIM/DMARC set.
5. **Content:** weekly LinkedIn posts with anonymised findings ("the IDOR we find in 7 of 10 fintech apps").
6. **Communities:** null Delhi, OWASP Delhi, BSides, startup meetups, TiE events.
7. **Listings:** Clutch, GoodFirms, Google Business Profile.

Convincing them

- Lead with their deadline: "Auditor-ready VAPT report in 15 working days, retest included."
- Show the redacted sample report on the first call.
- Start small: one fixed-price web or API test, then expand.
- Use only public, passive observations as openers (missing DMARC, expiring SSL, weak security headers). **Never scan or probe a prospect without written permission.**

Phase 3: deliver an engagement, start to finish

A typical web/API VAPT takes 3–4 weeks from signed scope to retest. First decide the route: if the client needs a CERT-In report, hand it to the partner at step 3 and stay as account manager.

1. **Discovery call (day 0):** why they need it, deadline, compliance framework, targets.
2. **Scoping (days 1–2):** count URLs, roles, API endpoints, IPs, mobile builds; send a scope sheet.
3. **Proposal and paperwork (days 2–5):** proposal, NDA, SOW, signed authorization letter, Rules of Engagement, test accounts, testing window. CERT-In route: introduce the partner here.
4. **Kick-off (day 6):** contacts on both sides, emergency stop procedure, IP addresses you'll test from.
5. **Testing (days 7–15):** automated scans plus manual testing against OWASP Top 10, OWASP API Top 10 and MASVS; business-logic and access-control testing by hand. Report critical issues to the client the same day.
6. **Report (days 15–18):** executive summary, scope, methodology, findings with CVSS score, evidence, impact, fix steps. Peer-review every report before it goes out.
7. **Readout call (day 19):** walk the CTO and developers through the findings.
8. **Retest (within 30–45 days):** verify fixes, issue the final report with status per finding.
9. **Close:** invoice, testimonial request, propose quarterly or annual retainer, delete client data on schedule.

Where Claude and Claude Code fit

Use Claude to cut sales, paperwork and reporting time; keep the actual testing with your certified humans and standard tools (Burp Suite, Nmap, Nuclei, MobSF and others). Claude won't write exploits or attack systems, so plan the testing itself around your testers.

Area	What Claude does	Time saved
Lead research	Builds target lists (funded startups, fintechs, compliance hiring), researches each company	Hours a week
Outreach	Writes personalised LinkedIn and email messages, partner pitches, follow-ups	Most of the writing

Area	What Claude does	Time saved
Proposals	Drafts proposals, SOWs, NDAs and authorization letters from your templates (have a lawyer review the templates once)	1-2 hours per deal
Scoping	Turns discovery-call notes into a scope sheet and price estimate	30-60 min
Reporting	Turns your testers' notes and evidence into clear finding write-ups, executive summaries and fix guidance	40-60% of report time
Content	Blog posts, LinkedIn posts, anonymised case studies	Most of the writing
Claude Code (tooling)	Builds your internal tools: a report generator that converts scanner exports and tester notes into your report template, a scope/price calculator, a client tracker, a findings library	Builds once, saves every engagement
Compliance mapping	Maps findings to ISO 27001, SOC 2, PCI DSS or RBI controls	Hours per report

What stays with humans: confirming every finding is real, judging severity, the testing itself, client sign-off and anything signed.

Data rule: don't paste client secrets, credentials or unredacted personal data into any AI tool unless your contract with the client allows it. Redact first.

Pricing and revenue math

Approximate Indian market ranges (not sourced; check 5-6 competitor quotes before you publish prices):

Service	Typical scope	Approx. price (INR, excl. GST)
Web app VAPT	Up to ~50 pages / 2-3 user roles	₹40,000-₹1,50,000
API VAPT	Up to ~50 endpoints	₹30,000-₹1,00,000
Mobile app VAPT	Android + iOS, one backend	₹50,000-₹1,50,000

Service	Typical scope	Approx. price (INR, excl. GST)
Network / infra VAPT	Per IP	₹1,000–₹3,000 per IP
AI chatbot / LLM app test	One bot plus its integrations	₹50,000–₹1,25,000
CERT-In audit via partner	Varies by scope	Partner price + your margin or referral fee

Example month at the 3-person stage: 3 web/API engagements at ₹75,000 = ₹2,25,000, plus 1 CERT-In referral at 15% of ₹2,00,000 = ₹30,000. Total about ₹2,55,000 a month. That covers a contract senior tester and a junior, so aim for 4+ engagements a month to be profitable.

Sell **annual retainers** (quarterly scans plus 1–2 full tests a year) as early as possible; they smooth out cash flow.

Path to your own CERT-In empanelment

Plan for 18–24 months. Your own empanelment is the only way to legitimately say "empanelled by CERT-In" and sign CERT-In reports yourself.

CERT-In opens applications in cycles and publishes the eligibility criteria with each round, so read the current guidelines on cert-in.org.in before planning. From memory, and approximately, they have looked for:

- A company registered in India with a track record in information security auditing
- A minimum number of full-time technical staff holding recognised certifications (such as CISSP, CISA, ISO 27001 Lead Auditor, OSCP)
- Evidence of completed audits (client work orders and reports)
- A technical evaluation, often a practical test on a target CERT-In provides

What to start doing now so you're ready:

- Keep every engagement's work order, completion letter and redacted report on file
- Hire and certify staff full-time, not only as contractors
- Get ISO 27001 certification for Saranik itself
- Build a written audit methodology and QA process

90-day plan

Goal by day 90: 2 signed CERT-In partners, 3 paid VAPT engagements done, and 2 case studies live.

Weeks 1-2: foundations

- ☐ @saranik.in email, SPF/DKIM/DMARC set
- ☐ Confirm your lead tester and their certifications
- ☐ VAPT on saranik.in, then build the redacted sample report
- ☐ Engagement documents drafted and reviewed by a lawyer

Weeks 3-4: launch

- ☐ VAPT landing page and Team section live
- ☐ Shortlist 25 CERT-In firms; send 10 partner messages a week
- ☐ Offer security checks to all existing AI clients
- ☐ 2 discounted pilot VAPTs in exchange for testimonials

Weeks 5-8: first revenue

- ☐ Sign the first 2 partner agreements
- ☐ 20 LinkedIn messages a day to target segments
- ☐ Sign 2 referral agreements with ISO/SOC 2 consultants or agencies
- ☐ Deliver pilots, publish the first case study

Weeks 9-12: repeatable

- ☐ 3 paid engagements completed
- ☐ First CERT-In referral sent to a partner
- ☐ Weekly LinkedIn post with anonymised findings
- ☐ Review: which segment and channel converted best, and double down

Sources

- [CERT-In: Empanelled information security auditing organisations](#)
- [CERT-In: Guidelines for empanelled auditors \(v3.0\)](#)
- [CERT-In: Terms and conditions for empanelment](#)